Third-Party and Cloud Security Policy

Acme Cloud Services KSA — Document ACS-POL-005, version 2.2, approved October 2025.

Synthetic demo document. Acme Cloud Services KSA is a fictional company and the controls, certificates and figures below are invented for testing.

1. Vendor tiering

Every supplier is tiered at onboarding according to the sensitivity of the data it can reach and its criticality to service delivery. The tier sets the depth of due diligence and the frequency of reassessment.

Tier	Criteria	Due diligence	Reassessment
Tier 1 Critical	Processes customer data, or a single point of failure	Full assessment, evidence review, right-to-audit clause	Annual
Tier 2 Important	Access to internal systems, no customer data	Questionnaire plus certification review	Every 2 years
Tier 3 Standard	No system or data access	Baseline screening	Every 3 years

No Tier 1 supplier is engaged without a completed assessment, a signed data processing agreement, and confirmation that its own security certifications are current. Contracts with Tier 1 suppliers include a right to audit, a security incident notification obligation of 24 hours, and a requirement to flow equivalent obligations down to their own sub-processors.

2. Sub-processors

Acme maintains a published sub-processor register on the Trust Portal. Customers receive 30 days' written notice before a new sub-processor is engaged and may object in that period. As of February 2026 Acme uses nine sub-processors: seven operate wholly within the Kingdom and two provide tooling from outside it under completed transfer assessments, neither with access to customer content.

3. Cloud controls

Acme is assessed as compliant with the NCA Cloud Cybersecurity Controls (CCC-1:2020) in the Cloud Service Provider tier. Customer environments are logically segregated by tenant, with separate encryption keys per tenant and enforced isolation at the network, compute and storage layers. Multi-tenancy isolation is tested as part of the annual external penetration test.

Infrastructure is defined as code and deployed through a reviewed pipeline; manual changes to production are blocked by policy-as-code and generate an alert. Cloud security posture management runs continuously against CIS benchmarks, with a current compliance score of 96 percent against the CIS AWS Foundations Benchmark.

4. Customer assurance

Customers may request the SOC 2 Type II report, ISO certificates, penetration test summary letters, and the annual NCA ECC self-assessment summary under NDA. Enterprise customers have a contractual right to audit Acme once per year with 30 days' notice, or more frequently following a material incident. Acme responds to customer security questionnaires within 15 business days.